Semana 05 — Evidencia explotada sin daño y sin datos de terceros

Grupo 3 · rol Legal y reporte · ejemplo de trabajo

Prof. César Rodríguez | ELECTRONICA | 1 de noviembre de 2026

Curso	CYBERSEGURIDAD — Ciberseguridad Aplicada
Semana	05 de 10
Fase	2 — Ofensiva controlada
Grupo	3
Rol	Legal y reporte
Entrega	GitHub, carpeta semana_05/
Corte	Domingo 23:59 de la semana correspondiente; lo posterior no se corrige.

1 Tu rol en la práctica

Verifica que el alcance y la autorización cubran lo ejecutado, anonimiza la evidencia, revisa la cadena de custodia e integra el informe técnico y el resumen ejecutivo.

- Revisar que el alcance y la autorización cubran exactamente lo ejecutado, ni más ni menos.
- Anonimizar la evidencia y verificar la cadena de custodia de cada archivo entregado.
- Integrar informe técnico y resumen ejecutivo, y declarar los límites del trabajo.

2 Qué aporta este rol al entregable

La versión final del informe y la declaración explícita de lo que no se pudo verificar.

3 Ejemplo paso a paso

El rol Legal revisa como se documenta la explotacion: que se extrajo, cuanto se conserva y como se evita que la evidencia se convierta en una fuga.

3.1 Declarar que datos se obtuvieron y con que limite

De la inyeccion se documenta el esquema y el numero de filas, no el contenido personal. Del LFI se guarda la linea que prueba la lectura, no el archivo completo.

3.2 Recortar y anonimizar la evidencia

Los nombres, correos y cualquier identificador se sustituyen por marcadores. El recorte se hace antes de guardar la copia que se versiona.

```
mkdir -p semana_05/evidencia
sed -E 's/[A-Za-z0-9._%+-]+@[A-Za-z0-9.-]+/[correo]/g' \
  semana_05/evidencia/extraccion.txt \
  > semana_05/evidencia/extraccion_anonima.txt 2>/dev/null || true
sha256sum semana_05/evidencia/extraccion_anonima.txt \
  > semana_05/evidencia/extraccion.sha256
```

3.3 Justificar la retencion y el borrado

La evidencia se conserva hasta el cierre de la evaluacion y despues se borra. El plazo se declara por escrito y se aplica igual para todos los grupos.

3.4 Revisar el informe contra el codigo de etica

Se comprueba que no hay capturas con datos reales, que no se publico ningun payload fuera del repositorio del grupo y que el alcance de la semana 3 cubre lo ejecutado.

3.5 Dato, tratamiento y fundamento

Dato, tratamiento y fundamento

Dato obtenido	Tratamiento	Se conserva	Plazo	Fundamento
Esquema de la base	Se documenta estructura	Si	Hasta cerrar	Autorizacion del alcance
Filas de usuarios	Solo conteo, sin contenido	Si	Hasta cerrar	Minimizacion
Contenido de /etc/passwd	Solo la linea que prueba acceso	Si	Hasta cerrar	Prueba del hallazgo
Datos personales reales	No se transcriben	No	Borrado inmediato	Proteccion de datos

La columna de fundamento cita la autorizacion de la semana 3 y la norma verificada; si falta, el dato no se conserva.

4 Qué guardar en el repositorio

Se entrega la evidencia anonimizada con su hash, la declaracion de retencion y la revision del informe contra el codigo de etica.

```
semana_05/
|-- informe.md
|-- evidencia/
|   |-- extraccion_anonima.txt
|   `-- extraccion.sha256
`-- README.md
```

- Ninguna captura contiene datos personales sin anonimizar.
- El plazo de retencion esta declarado y se cumple.
- Lo ejecutado esta cubierto por la autorizacion de la semana 3.
- El hash corresponde al archivo anonimizado, no al original.

5 Cómo se corrige

Criterio	Peso
Explotación reproducible de los tres tipos de vulnerabilidad	3,0
Causa raíz correctamente identificada	2,5
Mitigación concreta y verificable por hallazgo	2,0
Evidencia clara y anonimizada	1,5
Retos de Juice Shop justificados	1,0
Total	**10,0**

- Copiar datos reales "para demostrar el hallazgo" es una fuga, no una prueba.
- La anonimizacion se verifica abriendo el archivo final, no confiando en el comando.

Recuerda

El trabajo es independiente: cada grupo usa su propio repositorio y su propio laboratorio, y la comparación de resultados es en clase. Corte: Domingo 23:59 de la semana correspondiente; lo posterior no se corrige.